

Revocability is the standard

The rule is not “don’t commit secrets.” It is: how long does it take to revoke one — and that answer decides where a secret lives and how long it lasts.

Why the usual rule fails

ONE LEAK PATH OF MANY

A commit is one exit. Build logs, an error report, a screenshot in a ticket, a cached image and a laptop that has left the company are the others.

SILENT ON THE ONES ALREADY OUT

It is an instruction about tomorrow. Every credential already sitting in a repository, an image or a partner's config is untouched by adopting it.

NO FAILURE STATE

Nobody can observe a secret not being committed. There is nothing to check. A revocation either happened or it did not.

What makes rotation cheap

ONE ISSUER

One authority mints it and can end it. If two systems can both issue it, neither of them can retire it alone.

ONE PATH TO THE HOLDER

The workload reads it at run time from one place. Baked into an image or a config file, there is no single path to cut.

NO HUMAN IN THE LOOP

Rotation runs as a job on a schedule it owns. A rotation that needs a ticket happens after the incident, not before it.

Unrotatable means permanent

IT OUTLIVES ITS POLICY

The policy sets a lifetime, the plumbing sets the real one. Where the two disagree the plumbing wins, and the document is what is wrong.

EVERY COPY IS LOAD-BEARING

Embedded in a partner integration, a device image or a signed artifact, revoking it breaks something. So nobody does.

THE EXIT IS AN OUTAGE

It will be revoked eventually — during an incident, by someone who did not choose the moment and cannot see who still depends on it.

What we need to decide

01

THE KEEP RULE

Do we keep any secret we cannot rotate automatically, and if so under what named, dated and owned exception?

02

THE REVOKE BUTTON

Who can revoke, alone, at any hour, without asking permission — and when did they last do it?

03

THE ONES ALREADY OUT

What happens to the secrets already in circulation: rotate them now, or record that we treat them as permanent?